

A Guide to Implementing DevSecOps

DevSecOps incorporates security practices into DevOps to help ensure secure software development and delivery. The use of open source tools and a structured approach are crucial in achieving this objective.



Businesses can start their DevSecOps journey by carefully identifying security objectives and assessing the current state of security. Then, they must select the best open source tools for their needs and integrate these into the CI/CD pipeline, configuring and fine-tuning them to their preferences. Establishing security gates is essential, as is monitoring and responding to security incidents. By training teams and continuously improving the process, they can stay ahead of the curve. But they must always remember to prioritise security, automate everything possible, collaborate

openly, use infrastructure as code, implement security as code, manage vulnerabilities effectively, maintain compliance, monitor regularly, and continuously improve. With these guiding principles in mind, they will be well on their way to DevSecOps success.

Figure 1 and Table 1 list various security objectives in software development and delivery, along with the open source tools that can be used to achieve them.

By implementing an automated CI/CD pipeline with security integration, organisations can ensure that software is always secure. It's important to note

that this is not an exhaustive list of security tools, and there may be some overlap between security objectives. The reference architecture in Figure 1 is meant to provide a starting point for implementing DevSecOps practices with open source tools. With DevSecOps, organisations can ensure that software is always secure, allowing them to focus on their core business.

Best practices for enabling DevSecOps with open source tools

Implementing DevSecOps with open source tools can be complex, but following a few best practices can make